

Website Vulnerability Scanner Report

✓ **https://aku.web.brinesia.app/**

Target added due to a redirect from https://aku.web.brinesia.app

Summary

Overall risk level:

Low

Risk ratings:

Critical:

0

High:

0

Medium:

0

Low:

2

Info:

4

Scan information:

Start time: Sep 03, 2026 / 09:24:17 UTC+07

Finish time: Sep 03, 2026 / 09:32:09 UTC+07

Scan duration: 7 min, 52 sec

Tests performed: 77

Scan status: **Finished**

Findings

Unsafe security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://aku.web.brinesia.app/	Response headers include the HTTP Content-Security-Policy security header with the following security issues: <pre>script-src: 'unsafe-eval' allows the execution of code injected into DOM APIs such as eval(). object-src: We recommend restricting object-src to 'none'.</pre> Request / Response

▼ Details

Risk description:

For example, if the unsafe-inline directive is present in the CSP header, the execution of inline scripts and event handlers is allowed. This can be exploited by an attacker to execute arbitrary JavaScript code in the context of the vulnerable application.

Recommendation:

Remove the unsafe values from the directives, adopt nonces or hashes for safer inclusion of inline scripts if they are needed, and explicitly define the sources from which scripts, styles, images or other resources can be loaded.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:CWE : [CWE-1021](#)OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Server software and technology found

UNCONFIRMED



port 443/tcp

Software / Version	Category
 AngularJS	JavaScript frameworks
 HTTP/3	Miscellaneous
 PHP	Programming languages
 Cloudflare	CDN
 Cloudflare Turnstile	Security
 HSTS	Security

▼ Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:CWE : [CWE-200](#)OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)**Screenshot:**

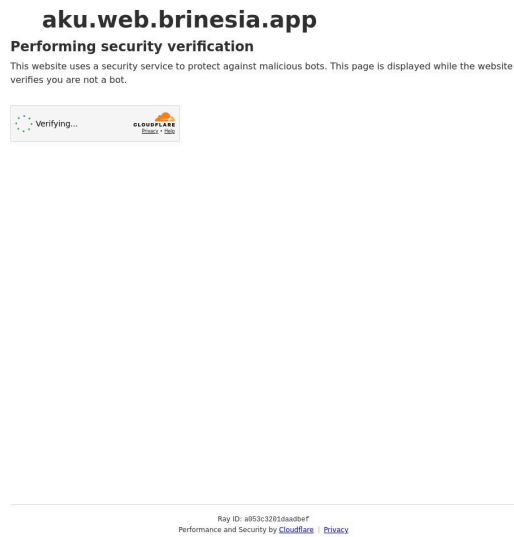


Figure 1. Website Screenshot



Input Reflected in Response

CONFIRMED

port 443/tcp

URL	Method	Vulnerable Parameter	Evidence	Replay Attack
https://aku.web.brinesia.app/	GET	ptt4d422dbf (Query Parameter)	Injected the string pttebebecda in the ptt4d422dbf query parameter and it was found reflected in the response. Request / Response	

Details

Risk description:

The risk is that the reflection of input without proper sanitization or encoding can potentially be leveraged by attackers to inject malicious scripts or content in the client browser context.

Recommendation:

It is recommended that a tester inspects this issue manually to find out if it can be escalated to higher-risk vulnerabilities.

References:

<https://owasp.org/www-community/attacks/xss>

https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

Classification:

CWE : [CWE-20](#)

OWASP Top 10 - 2021 : [A3 - Injection](#)

OWASP Top 10 - 2025 : [A05 - Injection](#)



Security.txt file is missing

CONFIRMED

port 443/tcp

URL

Missing: <https://aku.web.brinesia.app/.well-known/security.txt>

▼ Details

Risk description:

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Spider Results

UNCONFIRMED 

URL	Method	Parameters	Page Title	Page Size	Status Code
https://aku.web.brinesia.app/	GET		Just a moment...	30.96 KB	403
https://aku.web.brinesia.app/cdn-cgi/challenge-platform/h/g/orchestrate/chl_page	GET			39 B	403
https://aku.web.brinesia.app/cdn-cgi/challenge-platform/h/g/orchestrate/chl_page/v1	GET	Query: ray=a053c13bae79c4de		188.66 KB	404

▼ Details

Risk description:

The table contains all the unique pages the scanner found. The duplicated URLs are not available here as scanning those is considered unnecessary.

Recommendation:

We recommend to advanced users to make sure the scan properly detected most of the URLs in the application.

References:

[All the URLs the scanner found, including duplicates](#) (available for 90 days after the scan date)

 Misconfigurations

port 443/tcp

UNCONFIRMED 

URL	Page Title	Page Size	Summary
-----	------------	-----------	---------

https://aku.web.brinesia.app	Just a moment...	7.78 KB	Detected misconfigured CSP directives containing unsafe and overly permissive keywords that weakened resource loading restrictions. This configuration allowed high-risk script behaviors, resulting in reduced protection against XSS attacks.
---	------------------	---------	---

▼ Details

Risk description:

Depending on the misconfiguration present, the risk varies from information disclosure to possible execution of arbitrary code. A malicious actor can gain knowledge into the application's inner functionalities and services, obtain unauthorized access or make use of various security issues like execution of arbitrary code.

Recommendation:

We recommend you to analyze the configurations discovered, make sure the right options are set it, limit access to these resources and verify the application is not exposing information through these configurations.

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Scan coverage information

List of tests performed (77)

Port 443

- ✓ Scanned for website technologies
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for Input Reflected in response body
- ✓ Scanned for misconfigurations
- ✓ Scanned for absence of the security.txt file
- ✓ Performed web-crawling on target
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for client access policies
- ✓ Scanned for robots.txt file
- ✓ Scanned for CORS misconfiguration
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Performed Flowmapping
- ✓ Scanned for administration consoles
- ✓ Scanned for information disclosure
- ✓ Scanned for software identification
- ✓ Scanned for sensitive files
- ✓ Scanned for interesting files
- ✓ Performed URL search in Wayback Machine
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for GraphQL endpoints
- ✓ Performed fuzzing for OpenAPI files

- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for Cross-Site Scripting
- ✓ Scanned for SQL Injection
- ✓ Scanned for Local File Inclusion
- ✓ Scanned for OS Command Injection
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for code comments
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for XML External Entity Injection
- ✓ Scanned for Insecure Direct Object Reference
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for internal error code
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for Secure flag of cookie
- ✓ Scanned for login interfaces
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for Server Side Request Forgery
- ✓ Scanned for Open Redirect
- ✓ Scanned for PHP Code Injection
- ✓ Scanned for JavaScript Code Injection
- ✓ Scanned for Ruby Code Injection
- ✓ Scanned for Python Code Injection
- ✓ Scanned for Perl Code Injection
- ✓ Scanned for Remote Code Execution through Log4j
- ✓ Scanned for Server Side Template Injection
- ✓ Scanned for Remote Code Execution through VIEWSTATE
- ✓ Scanned for Prototype Pollution
- ✓ Scanned for Exposed Backup Files
- ✓ Scanned for Request URL Override
- ✓ Scanned for HTTP/1.1 Request Smuggling
- ✓ Scanned for CSRF
- ✓ Scanned for NoSQL Injection
- ✓ Scanned for Insecure Deserialization
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response

- ✔ Scanned for Path Disclosure
- ✔ Scanned for Session Token in URL
- ✔ Scanned for API endpoints
- ✔ Scanned for Response Header Injection
- ✔ Scanned for emails
- ✔ Scanned for missing HTTP header - Rate Limit
- ✔ Scanned for PEM-encoded private key material
- ✔ Scanned for partial PEM-encoded private key material

Scan parameters

Target:	https://aku.web.brinesia.app/
Scan type:	Deep
Authentication:	False
fingerprint:	True
software_vulnerabilities:	True
check_robots:	True
outdated_js:	True
untrusted_certificates:	True
client_access_policies:	True
http_debug_methods:	True
security_txt:	True
cors_misconfiguration:	True
resource_discovery:	True
sensitive_files:	True
admin_consoles:	True
interesting_files:	True
server_info_disc:	True
server_software:	True
misconfigurations:	True
graphql_endpoint:	True
fuzz_openapi_locations:	True
approach:	Auto
depth:	10
max_time:	3600
requests_per_second:	100
xss:	True
sqli:	True
lfi:	True
oscmdi:	True
ssrf:	True
open_redirect:	True
broken_authentication:	True
php_code_injection:	True
js_code_injection:	True
ruby_code_injection:	True
python_code_injection:	True
perl_code_injection:	True
log4j_rce:	True
ssti:	True
xxe:	True
viewstate_rce:	True
prototype_pollution:	True
backup_files:	True
request_url_override:	True
http_request_smuggling:	True

csrf:	True
insecure_deserialization:	True
nosqli:	True
session_fixation:	True
idor:	True
jwt:	True
response_header_injection:	True
security_headers:	True
cookie_security:	True
directory_listing:	True
secure_communication:	True
weak_password_submission:	True
error_debug_messages:	True
password_cleartext:	True
cross_domain_source:	True
mixed_content:	True
sensitive_data:	True
login_interfaces:	True
file_upload:	True
openapi_documents:	True
path_disclosure:	True
sql_statement_in_request:	True
password_in_response:	True
session_token_in_url:	True
api_endpoint:	True

Scan stats

Unique Injection Points Detected:	18
URLs spidered:	25
Total number of HTTP requests:	12956
Average time until a response was received:	7ms
Total number of HTTP request errors:	294

.....